



# LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



## CVE-2026-48172 LiteSpeed cPanel Plugin Privilege Escalation Vulnerability

CVE / Vulnerability Threat Intelligence Report

|                       |                                                |
|-----------------------|------------------------------------------------|
| <b>Classification</b> | TLP:CLEAR                                      |
| <b>Published</b>      | 2026-05-26                                     |
| <b>Version</b>        | 1.1                                            |
| <b>Author</b>         | Lost Boys Cyber                                |
| <b>Report Type</b>    | CVE / Vulnerability Threat Intelligence Report |

TLP:CLEAR | Lost Boys Cyber | CVE-2026-48172 LiteSpeed cPanel Plugin Privilege Escalation Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-05-26 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

## Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

# CVE-2026-48172 LiteSpeed cPanel Plugin Privilege Escalation Vulnerability

## 1. Executive Summary

CVE-2026-48172 is a critical privilege-escalation vulnerability in the LiteSpeed user-end cPanel plugin used on shared-hosting environments. LiteSpeed, the CVE record, NVD, and CISA's Known Exploited Vulnerabilities (KEV) catalog all align that attackers exploited the issue in the wild during May 2026 and that abuse can let a cPanel user execute arbitrary scripts as `root`.

The most important operational detail is scope: this is not a generic unauthenticated internet RCE against any LiteSpeed server. The strongest vendor-supported description is that any cPanel user account, including an attacker-created tenant account or a compromised hosting account, could abuse the `lsws.redisAble` pathway to escalate privileges on the underlying server. In multi-tenant shared-hosting environments, that can turn a single low-privilege account compromise into full host compromise.

Confidence is high because the KEV entry, CVE.org API record, NVD API entry, LiteSpeed's May 21 advisory, and LiteSpeed's release log all corroborate the vulnerability mechanics, active exploitation status, and remediation path. A nuance defenders should preserve in client messaging is that LiteSpeed first patched the original issue in cPanel plugin `2.4.5`, but later advised customers to move to cPanel plugin `2.4.7` bundled with WHM plugin `5.3.1.0` or later after additional security review and hardening.

## 2. Vulnerability Metadata

| Field                                           | Value                                                                                          |
|-------------------------------------------------|------------------------------------------------------------------------------------------------|
| CVE                                             | `CVE-2026-48172`                                                                               |
| Vulnerability name                              | `LiteSpeed cPanel Plugin Privilege Escalation Vulnerability`                                   |
| Product / component                             | LiteSpeed user-end cPanel plugin; related hardening also shipped with the LiteSpeed WHM plugin |
| Weakness                                        | `CWE-266` Incorrect Privilege Assignment                                                       |
| Severity                                        | Critical                                                                                       |
| CVSS v4.0 vector                                | `AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H` (10.0 / CRITICAL)                     |
| CVSS v3.1 vector                                | `AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` (9.8 / CRITICAL)                                         |
| CNA / CVE publication date                      | `2026-05-21`                                                                                   |
| CISA KEV addition date                          | `2026-05-26`                                                                                   |
| CISA due date for FCEB remediation              | `2026-05-29`                                                                                   |
| Exploitation status                             | listed by CISA KEV and tagged in the CVE record as a known exploited vulnerability             |
| Vulnerable version statement in CNA / NVD       | LiteSpeed user-end cPanel plugin before `2.4.5`                                                |
| Vendor-recommended minimum version after review | cPanel plugin `2.4.7` bundled with WHM plugin `5.3.1.0` or later                               |
| Related detection string from CNA / NVD         | `cpanel_jsonapi_func=redisAble`                                                                |

NVD configuration data also tracks the broader hardening boundary as LiteSpeed cPanel plugin versions earlier than `2.4.7` and LiteSpeed WHM plugin versions earlier than `5.3.1.0`, which matches LiteSpeed's recommendation to patch beyond the first emergency fix.

### 3. Source Review & Confidence

| Source          | Contribution                                                                                                               | Confidence                                                                                           |
|-----------------|----------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|
| Reviewed source | KEV feed entry states `CVE-2026-48172` affects the LiteSpeed cPanel Plugin, was added on `2026-05-26`, carries due date    | Strongest machine-readable source for active-exploitation status and CISA-required action.           |
| Primary source  | Public catalog entry corroborates that `CVE-2026-48172` is in KEV and points defenders to vendor mitigation guidance.      | Useful public-facing corroboration of the KEV listing, though the JSON feed is the cleaner structure |
| Reviewed source | CNA record describes a privilege-escalation flaw in the LiteSpeed user-end cPanel plugin before `2.4.5`, identifies `CWE   | Strongest source for the authoritative vulnerability description, affected-version statement, and ve |
| Primary source  | NVD mirrors the exploitation-in-the-wild description, publishes CVSS v4 `10.0 / CRITICAL` and CVSS v3.1 `9.8 / CRITICAL`   | Strong corroborating metadata source and the easiest place to retrieve structured severity and KEV f |
| Reviewed source | LiteSpeed says the issue affected the user-end cPanel plugin, was reported by David Strydom, allowed any cPanel user to    | Primary narrative source for impact, timeline, mitigation, and the emergency uninstall command.      |
| Reviewed source | Release log confirms `2.4.6` reintroduced Redis features with additional hardening and `2.4.7` / `5.3.1.0` added privilege | Strong corroborating vendor artifact for remediation chronology and version-floor recommendations.   |
| Reviewed source | Follow-up LiteSpeed advisory documents a later, separate privilege-escalation issue affecting CloudLinux/CageFS deployme   | Important scoping source to avoid conflating distinct issues; not the primary source for `CVE-2026-4 |

Confidence is high on both exploitation status and remediation direction: Confidence is lower only on exact attack preconditions beyond the vendor-supported description. Some third-party reporting loosely frames the issue as remotely exploitable without context, but the strongest reviewed sources consistently describe a cPanel-user abuse path rather than a universal unauthenticated server takeover. The June 1, 2026 LiteSpeed follow-up advisory concerns a later, separate privilege-escalation issue reported by Namecheap on CloudLinux/CageFS environments. It is useful as context that the plugin family required continued hardening, but it should not be conflated with `CVE-2026-48172` in client reporting.

### 4. Vulnerability Details

LiteSpeed states that the issue is related to mishandling of Redis enable / disable features in the user-end cPanel plugin. The public detection string and vendor narrative both point defenders to the `lsws.redisAble` function as the abuse surface.

Operationally, the flaw breaks the intended privilege boundary between a customer-level cPanel account and the underlying server. An attacker who can operate through a cPanel user account can trigger behavior that executes arbitrary scripts as `root`, converting tenant-level access into full system-level control.

The vendor's own remediation history matters:

- LiteSpeed says the original vulnerability was patched in cPanel plugin `2.4.5`.
- On `2026-05-19`, cPanel pushed an uninstall command for the user-end plugin, and LiteSpeed released cPanel plugin `2.4.6` with WHM plugin `5.3.0.0`.

- After an additional security review, LiteSpeed released cPanel plugin `2.4.7` bundled with WHM plugin `5.3.1.0` and recommended that as the minimum safe version.

This means defenders should not stop at identifying whether `2.4.5` was ever installed; they should verify that estate versions reached the vendor's later recommended build or that the user-end plugin was removed.

## 5. Attack Scenarios

1. An attacker signs up for or compromises a low-tier shared-hosting cPanel account on a server using the vulnerable LiteSpeed user-end plugin, then abuses the `redisAble`-related path to execute a script as `root`.
2. A threat actor steals one customer's cPanel credentials and uses the plugin flaw to pivot from a single tenant account into full compromise of the shared-hosting node.
3. An intrusion affecting a hosted website yields web-shell or account-level control for one tenant, after which the attacker escalates privileges through the vulnerable plugin and can access neighboring tenants or the underlying host.
4. A hosting provider that delayed plugin upgrades after the initial disclosure remains exposed even if operators believed the first emergency patch was sufficient and never moved to the later hardened build.

## 6. Threat Landscape & Exploitation Status

- `CVE-2026-48172` is not merely theoretical; CISA added it to the KEV catalog on `2026-05-26`, and both the CVE record and NVD explicitly state it was exploited in the wild in May 2026.
- The attack is especially relevant for shared-hosting providers, managed hosting companies, resellers, and organizations still operating cPanel-based multi-tenant infrastructure with LiteSpeed integrations.
- The practical business risk is asymmetric: one compromised or attacker-controlled cPanel user may be enough to jeopardize the confidentiality, integrity, and availability of the entire server and potentially co-hosted customer environments.
- LiteSpeed's advisory language and cPanel's decision to push an uninstall command both indicate an urgent response posture rather than routine maintenance.
- No authoritative source reviewed here attributes exploitation to a named threat actor or ransomware campaign, and the KEV feed marks known ransomware campaign use as `Unknown`.

## 7. Affected Products and Exposure

Directly affected:

- Servers running LiteSpeed's user-end cPanel plugin versions earlier than `2.4.5` per the CNA / NVD vulnerability statement.
- Hosting estates that never advanced to LiteSpeed's later recommended hardening level of cPanel plugin `2.4.7` with WHM plugin `5.3.1.0` or later.
- Shared-hosting environments where many untrusted or semi-trusted customer accounts share the same underlying server.
- Environments where cPanel access is broadly delegated, weakly monitored, or commonly exposed through password reuse, infostealer activity, or commodity phishing.

Higher-risk patterns:

- Multi-tenant hosting nodes with large numbers of customer cPanel accounts.
- Providers that permit rapid self-service account creation and do not aggressively monitor tenant-to-root abuse patterns.
- Servers where the LiteSpeed user-end plugin remained installed during the May 2026 exploitation window.
- Environments without central log collection for `/var/cpanel/logs` and `/usr/local/cpanel/logs`.

Lower-risk patterns:

- Systems where the user-end cPanel plugin was uninstalled or disabled during the emergency response period.
- Servers confirmed at cPanel plugin `2.4.7+` and WHM plugin `5.3.1.0+`.
- Single-tenant administrative environments where arbitrary customer-level cPanel access does not exist.

## 8. Mitigation and Workarounds

Priority actions:

5. Upgrade to LiteSpeed WHM plugin `5.3.1.0` bundled with cPanel plugin `2.4.7` or later; do not treat `2.4.5` alone as the end state if the environment missed later vendor hardening.
6. If immediate upgrade is not possible, use LiteSpeed's emergency uninstall path for the user-end plugin:
  - ``/usr/local/lsws/admin/misc/lscmctl cpanelplugin --uninstall``
7. Run the vendor-recommended detection command to identify exploitation attempts:
  - ``grep -rE "cpanel_jsonapi_func=redisAble" /var/cpanel/logs /usr/local/cpanel/logs/ 2>/dev/null``
8. For any hit returned by that command, review the associated source IPs, determine whether they are legitimate, and inspect system logs for follow-on activity from those IPs.
9. Reset credentials and review persistence on any server where suspicious `redisAble`-related activity is found, because successful abuse may have granted `root` execution.
10. Reduce blast radius by limiting unnecessary cPanel account sprawl, enforcing MFA where possible, and monitoring for abnormal cPanel account creation or compromise.

For federal environments, CISA's KEV action remains the authoritative urgency signal: apply vendor mitigations, follow BOD 22-01 guidance for cloud services where applicable, or discontinue use if mitigations are unavailable.

## 9. Detection Engineering

Strongest public detection guidance comes directly from the vendor and should be operationalized in SIEM and log management:

| Signal                                                                                                                                                                                              | Telemetry Source                                           | Analytic Goal                                                           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|-------------------------------------------------------------------------|
| Search cPanel logs for `cpanel_jsonapi_func=redisAble`, which LiteSpeed and NVD explicitly call out as the best public detection starting point.                                                    | Asset inventory / service / security telemetry             | Identify vulnerable systems, exposure, or suspicious follow-on activity |
| Alert on cPanel JSON API requests invoking Redis enable / disable functionality from unusual source IPs, newly created customer accounts, or accounts that normally do not manage caching features. | Asset inventory / service / security telemetry             | Identify vulnerable systems, exposure, or suspicious follow-on activity |
| Correlate `redisAble` activity with subsequent `root`-level process execution, cron modifications, SSH key changes, user creation, web shell writes, or service configuration changes.              | Asset inventory / service / security telemetry             | Identify vulnerable systems, exposure, or suspicious follow-on activity |
| Build detections around bursts of cPanel API activity followed by system-log evidence of privilege boundary crossing on the same host.                                                              | Asset inventory, SBOM, package management, CI/CD telemetry | Find vulnerable builds or packages                                      |
| Retain and centralize `/var/cpanel/logs` and `/usr/local/cpanel/logs/` because local-only logging materially weakens post-incident review.                                                          | Asset inventory / service / security telemetry             | Identify vulnerable systems, exposure, or suspicious follow-on activity |

### 9.1 Detection Query

```
// Asset and version discovery pivots for CVE-2026-48172 LiteSpeed cPanel Plugin Privilege Escalation
```

```
Vulnerability
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("dpkg -l", "rpm -qa", "apt list --installed", "pip show", "go
version", "syft", "grype")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine
| order by Timestamp desc
```

## 9.2 Exposure / Triage Query

```
// Service or exposure triage pivots related to CVE-2026-48172 LiteSpeed cPanel Plugin Privilege
Escalation Vulnerability
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

## 10. Threat Hunting

Suggested hunt questions:

- Which internet-facing servers still run LiteSpeed cPanel plugin builds older than `2.4.7` or WHM plugin builds older than `5.3.1.0`?
- Do any cPanel or WHM logs contain `cpanel\_jsonapi\_func=redisAble` during or after the May 2026 exploitation window?
- Which source IPs invoked the Redis-related API path, and did those IPs later authenticate to SSH, create cron jobs, modify web roots, or touch `/root`, `/etc`, or service configuration paths?
- Did any newly created, low-activity, or geographically unusual cPanel accounts interact with Redis management features shortly before host-level anomalies?
- On shared-hosting nodes, were there cross-tenant signs of follow-on compromise after suspicious plugin activity, such as access to multiple account home directories or mass file modification?
- Which servers relied on the emergency uninstall command instead of an upgrade, and were those removals verified successfully?

### 10.1 Hunt Query

```
// Service or exposure triage pivots related to CVE-2026-48172 LiteSpeed cPanel Plugin Privilege
Escalation Vulnerability
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

## 11. MITRE ATT&CK Mapping

The strongest evidence-supported ATT&CK mappings for this exploitation path are:

- `T1068` Exploitation for Privilege Escalation: the core issue allows a lower-privilege cPanel user context to obtain `root` execution on the server.
- `T1078` Valid Accounts: the vendor's impact description assumes abuse by a cPanel user account, which can include a legitimately created tenant account or a compromised customer account.
- `T1059` Command and Scripting Interpreter: successful exploitation enables arbitrary script execution as `root`.

Post-exploitation may involve many other ATT&CK techniques, but the three mappings above are the strongest ones directly supported by the reviewed vendor and vulnerability records.

## 12. Validation / Lab Testing

This review validated the draft against authoritative public records and vendor advisories rather than reproducing the exploit in a Lost Boys Cyber lab. Analyst validation steps completed:

- Reviewed the CISA KEV JSON feed and catalog entry to confirm exploitation status, required action, and due date.
- Queried the CVE.org API record for the authoritative description, CWE, affected-version statement, and vendor solution guidance.
- Queried the NVD JSON 2.0 API for corroborating severity, CISA KEV metadata, and configuration boundaries.
- Reviewed LiteSpeed's May 21, 2026 security advisory for impact language, detection guidance, mitigation commands, and response timeline.
- Reviewed LiteSpeed's control-panel plugin release log to confirm the progression from `2.4.5` to `2.4.6` and finally `2.4.7` / `5.3.1.0` hardening.
- Reviewed LiteSpeed's June 1, 2026 follow-up advisory to ensure later plugin-family issues were not mistakenly merged into the `CVE-2026-48172` narrative.

No local proof-of-concept execution or exploit replay was performed during this review, and no claim is made here that Lost Boys Cyber independently reproduced exploitation.

## 13. Recommended Actions Summary

| Priority | Owner                         | Action                                                                                                                                                                                                        |
|----------|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| High     | Security / Platform Owners    | Treat `CVE-2026-48172` as a high-priority shared-hosting containment issue because it can turn one cPanel account into `root` on the host.                                                                    |
| Critical | Platform / Application Owners | Verify not only whether the original issue was patched, but whether each affected server actually reached LiteSpeed's recommended hardened version floor of cPanel plugin `2.4.7+` and WHM plugin `5.3.1.0+`. |
| High     | SOC / Detection Engineering   | Hunt immediately for `cpanel_jsonapi_func=redisAble` across cPanel logs and treat any unexplained hits as possible server-compromise leads.                                                                   |
| High     | Security / Platform Owners    | On any suspicious host, perform root-level post-exploitation review: credentials, cron, startup persistence, SSH keys, web-root modifications, and cross-tenant access.                                       |
| High     | SOC / Detection Engineering   | Reduce future blast radius by minimizing unnecessary tenant account exposure, improving authentication controls, and centralizing cPanel / WHM logging.                                                       |

## 14. References

11. CISA Known Exploited Vulnerabilities JSON feed, `CVE-2026-48172`

12. CISA Known Exploited Vulnerabilities catalog entry, `CVE-2026-48172`



13. CVE.org API record, `CVE-2026-48172`
14. NVD JSON 2.0 API, `CVE-2026-48172`
15. LiteSpeed Blog, `Security Update for LiteSpeed cPanel Plugin` (2026-05-21)
16. LiteSpeed control-panel support release log
17. LiteSpeed Blog, `Security Update for LiteSpeed cPanel Plugin` (2026-06-01 follow-up advisory for separate later issue)